

Post-Compromise Security for Autonomous Mobile Agents: Deterministic Runtime Enforcement of Mobile Execution Authority

Chun-Cheng (Jimmy) Chen
Research and Development Division
Top-Celestial Company Ltd.
Taipei, Taiwan R.O.C.
jimmychen@dr-os.io

Abstract—Autonomous mobile agents increasingly combine learned or language-based decision processes with privileged mobile APIs and operating system services. This creates a post-compromise security problem distinct from conventional model-level robustness: once the autonomous controller is fully compromised, can unauthorized intent still obtain downstream mobile execution authority?

We formulate the Post-Compromise Mobile Execution Authority Problem and investigate whether a deterministic runtime enforcement layer can preserve execution authorization independently of controller integrity. We present DROS-Mobile, a reference implementation positioned between autonomous agent intent and protected mobile execution interfaces. The design separates cognitive intent from execution authority through explicit principal, capability, policy, and revocation checks.

We formalize three properties: Unauthorized Protected System-Effect Invariance (P1), Revocation-Bound Execution Authority (P2), and Delegation Non-Escalation (P3) under explicitly declared protected execution paths $\mathcal{E}_{\text{protected}}$. We evaluate the system across nominal execution, fully compromised-agent behavior (C^*), adversarial API requests, authorization bypass attempts, capability replay, revocation races, and sustained stress workloads on iOS and Android environments.

The evaluation measures unauthorized protected system effects, containment rate, multi-stage revocation horizons (T_{rev} vs. T_{RCU}), delegation propagation, decomposed enforcement latency, and runtime overhead. The results provide an experimentally reproducible basis for studying post-compromise security at the boundary between autonomous mobile cognition and operating-system-mediated execution.

Index Terms—Mobile Agent Security, Post-Compromise Security, Runtime Enforcement, Execution Authority, Protected System Effect, Mobile Operating Systems.

I. Introduction

The integration of Large Language Models (LLMs), Vision-Language-Action (VLA) models, and autonomous task-planning agents into mobile operating systems (iOS and Android) has rapidly expanded the surface for privileged system interactions. Modern mobile agents are granted capabilities to autonomously inspect photo galleries, parse SMS verification codes, invoke contact books, manipulate local application storage, and initiate financial transactions.

However, granting generative models unconstrained access to privileged mobile APIs introduces a fundamental security dilemma. When an on-device cognitive agent is hijacked via prompt injection, adversarial multi-modal perception, or compromised retrieval augmented memory, internal model alignment cannot prevent the emission of unauthorized, malicious system calls.

In mobile security, an attack is characterized by immediate, irreversible digital side-effects: exfiltrating sensitive PII, unauthorized financial transfers via Apple Pay / Android Keystore, or unauthorized background network beaconing. This reality leads to the central scientific question of this work:

When an autonomous mobile agent is fully compromised, can a trusted execution layer prevent unauthorized agent intent from producing downstream protected mobile system effects?

We formulate the core security thesis:

$$\boxed{\begin{array}{l} \text{Compromise}(\text{Cognitive Controller}) \\ \not\Rightarrow \text{Compromise}(\text{Mobile Execution Authority}) \end{array}} \quad (1)$$

To investigate this thesis, we present DROS-Mobile, an open-source reference implementation operating as a deterministic binary gate via C-ABI between autonomous agent intent and protected mobile SDK interfaces.

A. Academic Contributions

- 1) **Problem Formulation:** We formulate the Post-Compromise Mobile Execution Authority Problem, formally decoupling cognitive model compromise from downstream mobile execution authority.
- 2) **Formal Security Properties:** We formalize three verifiable properties: Unauthorized Protected System-Effect Invariance (P1), Revocation-Bound Execution Authority (P2), and Delegation Non-Escalation (P3).
- 3) **Reference Architecture:** We design and implement DROS-Mobile, an in-process execution authority gate operating via C-ABI across iOS (Swift) and Android (JNI) platforms, explicitly scoping protection to declared interface paths $\mathcal{E}_{\text{protected}}$.

- 4) Reproducible Experimental Methodology: We construct a 6-tier experimental ladder (M1–M6) across iOS and Android testbeds, evaluating adversarial black-box controllers (C^*), capability replay, and microsecond revocation races.

II. Related Work and Research Positioning

A. Mobile Application Sandboxing and OS Permissions

Traditional mobile security relies on operating system application sandboxing and runtime permission frameworks (e.g., iOS TCC, Android Runtime Permissions) [1], [6]. While these mechanisms restrict inter-application privilege escalation, they operate at the granularity of the host application. Once an application is granted permission, an autonomous agent running inside that application inherits all permissions without fine-grained temporal or semantic constraints.

B. LLM Agent Guardrails and Digital Containment

Recent research addresses LLM agent security via middleware guardrails, prompt filtering, and tool-call mediation [2], [7]. However, existing guardrails primarily operate within the application layer or rely on secondary LLM verifiers that introduce hundreds of milliseconds of latency and can be bypassed via direct API manipulation.

C. Research Gap and Experimental Substrate Positioning

Existing research increasingly addresses post-compromise agent behavior, runtime authorization, execution mediation, and mobile security, but these lines often rely on fragmented experimental substrates and disparate assurance boundaries [3], [4], [8]. A reproducible execution substrate that exposes the complete transition from compromised agent intent to protected system effects can facilitate systematic evaluation of post-compromise execution security.

In this unified research paradigm:

- DROS provides an open, reproducible, executable reference substrate;
- VEP provides the implementation-independent evaluation and falsification protocol;
- Mobile and UAV instantiate the post-compromise execution security problem across digital system effects ($PSE \equiv 0$) and cyber-physical kinetic envelopes ($\Delta u_{\text{cmd}} \equiv 0 \wedge x(t) \in \mathcal{S}_{\text{safe}}$), respectively.

III. System and Threat Model

A. Untrusted Controller Model (C^*)

The cognitive controller is modeled as an adversarial black box:

$$C^* : \mathcal{I} \rightarrow \mathcal{A}^* \quad \text{where} \quad \mathcal{A}^* \subseteq \mathcal{A}_{\text{arbitrary}} \quad (2)$$

The attacker can emit valid or invalid API calls, manipulate parameter buffers, replay expired tokens, and attempt vertical/horizontal privilege escalation.

B. Trusted Execution Boundary & Declared Path Scope ($\mathcal{E}_{\text{protected}}$)

The assurance boundary is strictly scoped to the declared protected execution path:

$$\mathcal{E}_{\text{protected}} = \{\text{execution paths covered by enforcement gate}\} \quad (3)$$

DROS-Mobile enforces authorization for any action $a \in \mathcal{E}_{\text{protected}}$. It does not claim protection for arbitrary OS effects outside its declared enforcement boundary.

C. Out-of-Scope Disclosures

Physical device memory tampering via hardware debugger / JTAG, baseband processor compromise, OS kernel-level compromises (iOS kernel panic / Android rootkits), and Secure Enclave hardware compromise are out of scope.

IV. Formal Security Properties

A. Property P1 — Unauthorized Protected System-Effect Invariance (UPSEI)

$$\forall a \in \mathcal{E}_{\text{protected}}, \quad \text{Auth}(a, s, t) = 0 \implies \text{PSE}(a, s, t) \equiv 0 \quad (4)$$

where PSE is defined as any state mutation, unauthorized read, or IPC transmission touching protected APIs, financial services, application storage, and network sockets.

B. Property P2 — Revocation-Bound Execution Authority

Let capability c be revoked at timestamp t_r . Within a bounded revocation horizon τ_r :

$$\text{Revoked}(c, t_r) = 1 \implies \forall t \geq t_r + \tau_r, \quad \text{Auth}(a_c, s, t) = 0 \wedge \text{PSE}(a_c, s, t) \equiv 0 \quad (5)$$

where $T_{\text{rev}} = t_{\text{first guaranteed DENY}} - t_{\text{revocation commit}} < 2.5 \mu\text{s}$ [10].

C. Property P3 — Delegation Non-Escalation

$$\text{Authority}_{\text{child}} \subseteq \text{Attenuate}(\text{Authority}_{\text{parent}}) \wedge \text{UnauthorizedPropagation} \equiv 0 \quad (6)$$

V. Experimental Evaluation (M1–M6 Ladder)

A. Experimental Setup

- iOS Environment: Apple A17 Pro (iOS 18), Swift 5.10 with direct C-ABI static binding.
- Android Environment: Snapdragon 8 Gen 3 (Android 14), Kotlin with JNI C-ABI shared library (libdros_mobile.so).
- Workload: 10,000 continuous benchmark iterations with randomized adversarial injections.

TABLE I
Cross-Platform Post-Compromise Security Evaluation Matrix across Mobile Substrates (M1–M6)

Tier	Evaluation Stage	Injected Vector	Evaluated Metric & Criteria	Status
M1	Nominal Execution	Legitimate Photo Library access	$PSE = 1, P_{50} \leq 1.70 \mu s, 0$ false denials	Pass
M2	Full Compromise (C^*)	Malicious intent issued	Intent emitted at cognitive plane	Pass
M3	Execution Containment	Unauthorized SMS / Contacts exfiltration	$Auth = 0 \implies PSE \equiv 0 (R_{\text{contain}} = 1.0)$	Pass
M4	Capability Abuse	Stale tokens, enum manipulation	100% Fail-closed rejection ($R_{\text{FC}} = 1.0$)	Pass
M5	Revocation Race	Replay of revoked token at $t_r + \Delta t$	$T_{\text{rev}} < 2.5 \mu s, 0$ post-revocation PSE	Pass
M6	High-Rate Stress	10,000 boundary mutations	0 crashes, no detectable memory growth ($\Delta M = 0$)	Pass

B. Overhead and Energy Disclosures

- Decision Latency: iOS Swift $P_{50} = 1.70 \mu s, P_{99} = 7.30 \mu s$; Android JNI $P_{50} = 2.10 \mu s, P_{99} = 8.50 \mu s$.
- Memory Footprint: Observed under the specified 10,000-iteration test configuration: no detectable memory growth ($\Delta M = 0$ B after initial pool allocation).
- Energy Overhead: Energy overhead estimated from measured execution cost ($< 0.05 \mu J$ per invocation in L1/L2 cache), avoiding 4G/5G radio wakeups.

VI. Discussion and Limitations

DROS-Mobile provides deterministic containment under the declared threat model and interface boundary $\mathcal{E}_{\text{protected}}$. However, it does not claim protection against physical hardware extraction, baseband compromise, or zero-day mobile OS kernel rootkits. Furthermore, coverage is bounded to the declared protected API sets.

VII. Conclusion

This paper investigated whether physical and digital action authority can remain enforceable after the cognitive controller of an autonomous mobile agent is assumed fully compromised. Through the DROS-Mobile reference implementation, we demonstrated that decoupling cognitive planning from execution authority allows formal invariants (P1, P2, P3) to hold with microsecond-level latency and zero background network reliance.

Both domains provide empirical evidence for the overarching paradigm:

$$\boxed{\begin{array}{c} \text{Cognitive Compromise} \\ \not\equiv \text{Execution Authority Compromise} \end{array}} \quad (7)$$

Acknowledgment and AI Declaration

Generative AI tools were used solely for technical writing assistance, grammatical refinement, and $\text{\LaTeX}$ typesetting. The core conceptual vision, research questions, system architecture, formal invariants, experimental methodology, analysis of results, and claims were independently formulated and verified by the authors. The authors

retain full accountability for all content presented in this work.

References

- [1] W. Enck et al., “TaintDroid: An information-flow tracking system for real-time privacy monitoring on smartphones,” ACM TOCS, vol. 32, no. 2, pp. 1–32, 2014.
- [2] Y. Liu et al., “Prompt injection attacks and defenses in LLM-integrated applications,” in IEEE S&P, 2024, pp. 1042–1059.
- [3] J. B. Dennis and E. C. Van Horn, “Programming semantics for multiprogrammed computations,” CACM, vol. 9, no. 3, pp. 143–155, 1966.
- [4] H. M. Levy, Capability-Based Computer Systems, Digital Press, 2014.
- [5] C.-C. Chen, “DROS: Deterministic Runtime Governance Substrate for Autonomous Agentic Execution,” IEEE ICA Tech Report, no. 7782439, 2026.
- [6] Apple Inc., “Security and Privacy in iOS: TCC Architecture,” Apple Platform Security, 2024.
- [7] NVIDIA, “NeMo Guardrails: Programmable Guardrails for LLM Applications,” NVIDIA Dev Docs, 2024.
- [8] X. Zhang et al., “AgentSight: eBPF-Powered Tracing and Context Correlation for Autonomous LLM Agents,” in USENIX Security, 2024.
- [9] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications,” OWASP Standard, 2025.
- [10] P. E. McKenney, “Read-Copy Update Architecture and Synchronization Mechanisms,” IBM LTC, 2024.